

**UNIVERSIDAD POLITÉCNICA DE
SAN LUIS POTOSÍ**

CARRERA: Ingeniería en Tecnologías de la Información

MATERIA: CNO IV Seguridad Informática

TRABAJO: Lab File path traversal, validation of start of path

Ojeda Camacho José Carlos / 181629

PROFESOR: Servando Contreras

Contenido

Información del laboratorio	2
Objetivo del laboratorio.....	2
Explicación técnica de la vulnerabilidad	2
Procedimiento paso a paso	3
Explicación del payload	6
Mitigación recomendada.....	6

Información del laboratorio

Nombre del laboratorio: File Path Traversal, Validation of Start of Path

Nivel (Apprentice / Practitioner): Practitioner

Tipo de explotación: Path Traversal / Local File Inclusion (LFI)

Objetivo del laboratorio

El objetivo de este laboratorio es explotar una vulnerabilidad de path traversal en la visualización de imágenes de productos. La aplicación transmite la ruta completa del archivo y valida que la ruta suministrada comience con la carpeta esperada; para resolverlo, debes evadir esta restricción lógica utilizando secuencias de salto después de la ruta base autorizada y lograr extraer con éxito el contenido del archivo crítico del sistema operativo, `/etc/passwd`.

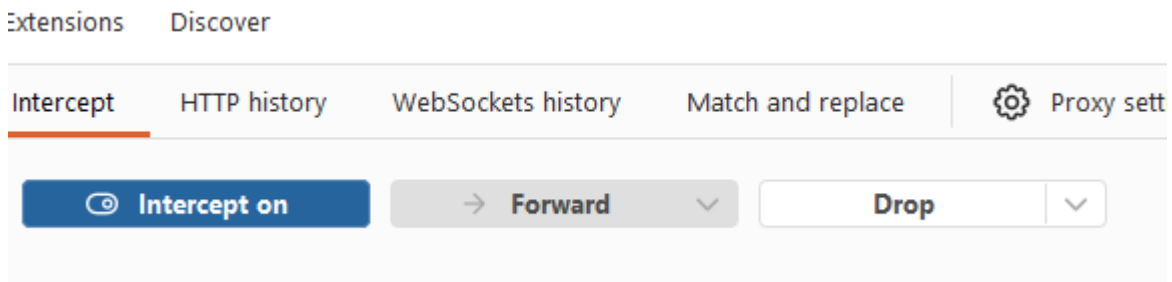
Explicación técnica de la vulnerabilidad

La vulnerabilidad radica en una deficiencia en el control de acceso y en la validación de entradas de la aplicación. El sistema intenta asegurar la lectura de archivos verificando estrictamente que el parámetro de entrada comience con un directorio base específico (por ejemplo, `/var/www/images/`). Sin embargo, el backend no sanitiza ni normaliza la ruta para eliminar las secuencias relativas de navegación (como `../`) que se añaden posteriormente.

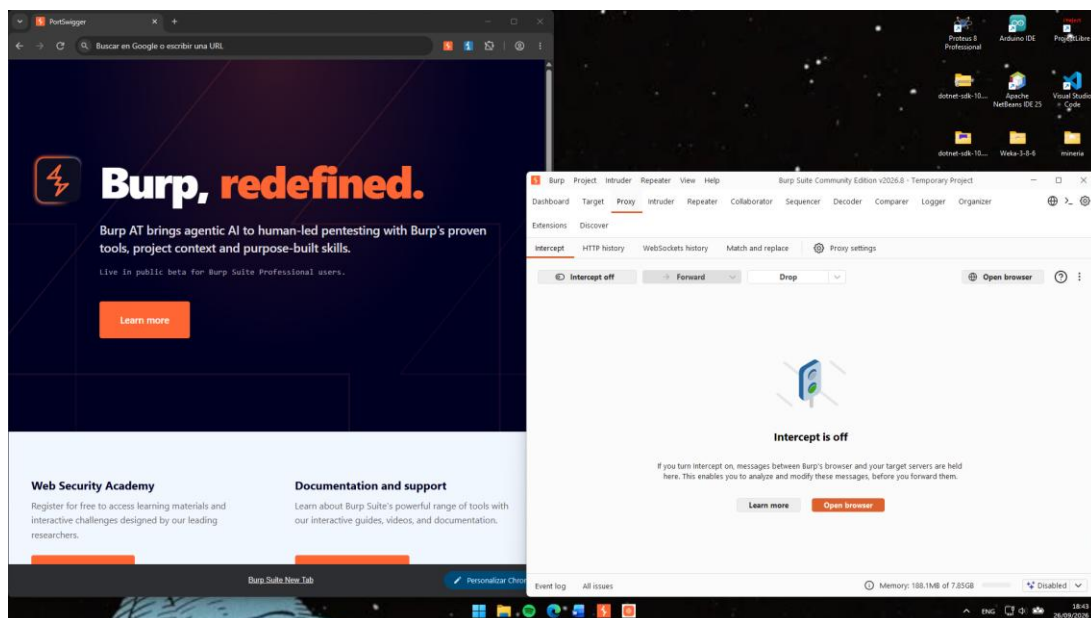
Esto permite a un atacante construir una ruta que satisfaga la validación inicial del prefijo, pero que inmediatamente después utilice secuencias de salto para retroceder a la raíz del servidor y acceder de manera ilegítima a recursos críticos del sistema operativo, tales como el archivo `/etc/passwd`.

Procedimiento paso a paso

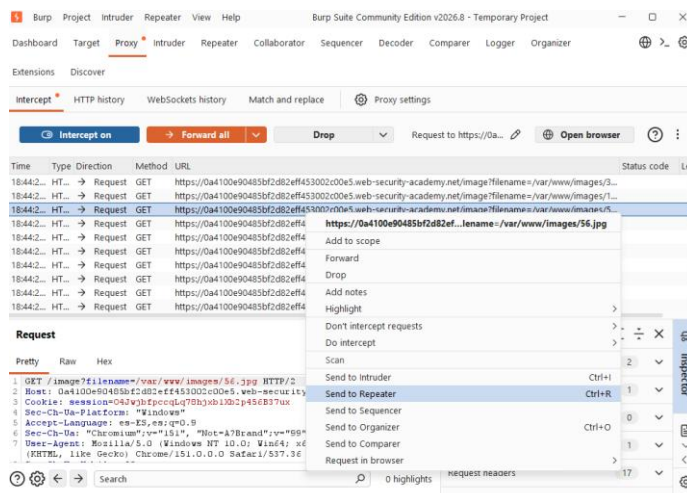
El proceso inicia con la apertura de la aplicación Burp Suite y el uso de su navegador integrado, el cual evita conflictos de configuración con certificados de seguridad. Posteriormente, en la sección Proxy > Intercept, se verifica que la función de intercepción se encuentre activada (*Intercept is on*). Esto permite pausar y capturar de manera temporal las peticiones HTTP generadas por el navegador antes de que alcancen el servidor de la aplicación, facilitando así su análisis y posterior modificación.



El uso del navegador integrado en Burp Suite facilita el análisis de tráfico web al enrutar las solicitudes de forma automatizada sin requerir configuraciones adicionales de certificados de seguridad. Una vez que la intercepción está activa y la petición queda retenida en el panel de control, la opción Forward permite liberar individualmente cada paquete HTTP retenido, enviándolo hacia su destino final en el servidor, o bien continuar el flujo normal de navegación una vez que se han realizado las inspecciones o modificaciones necesarias.



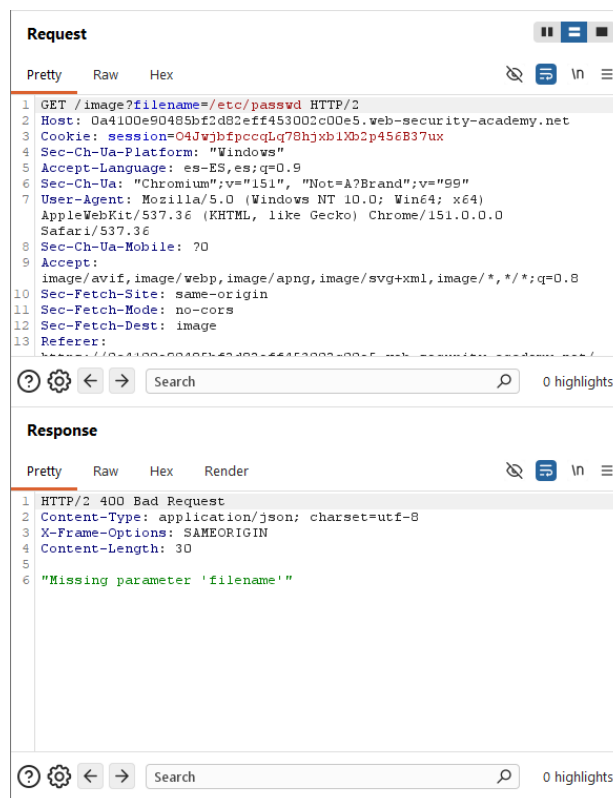
Una vez capturada la solicitud HTTP objetivo en el historial del proxy o durante la intercepción (específicamente la petición GET /image?filename=/var/www/images/XX.jpg), se hace clic derecho sobre ella para desplegar el menú contextual y se selecciona la opción Send to Repeater. Esta acción traslada la petición a la herramienta Repeater de Burp Suite, la cual permite reenviar de forma manual y controlada tantas solicitudes como sea necesario, facilitando la prueba de iteraciones y modificaciones en los parámetros sin requerir una nueva interacción directa desde el navegador web.



Dentro de la herramienta Repeater, se procede a modificar los parámetros de la petición HTTP capturada.

Específicamente, en la solicitud GET /image?filename=, se realizan los siguientes intentos para comprender el filtro de seguridad:

1. **Intento 1: Ruta absoluta (/etc/passwd).** Se elimina la ruta predeterminada y se reemplaza directamente con la ruta absoluta del archivo objetivo. El servidor responde con un error indicando que falta un parámetro o que el archivo no se encuentra. Esto confirma que la aplicación rechaza cualquier entrada que no inicie explícitamente con el directorio base esperado (/var/www/images/).

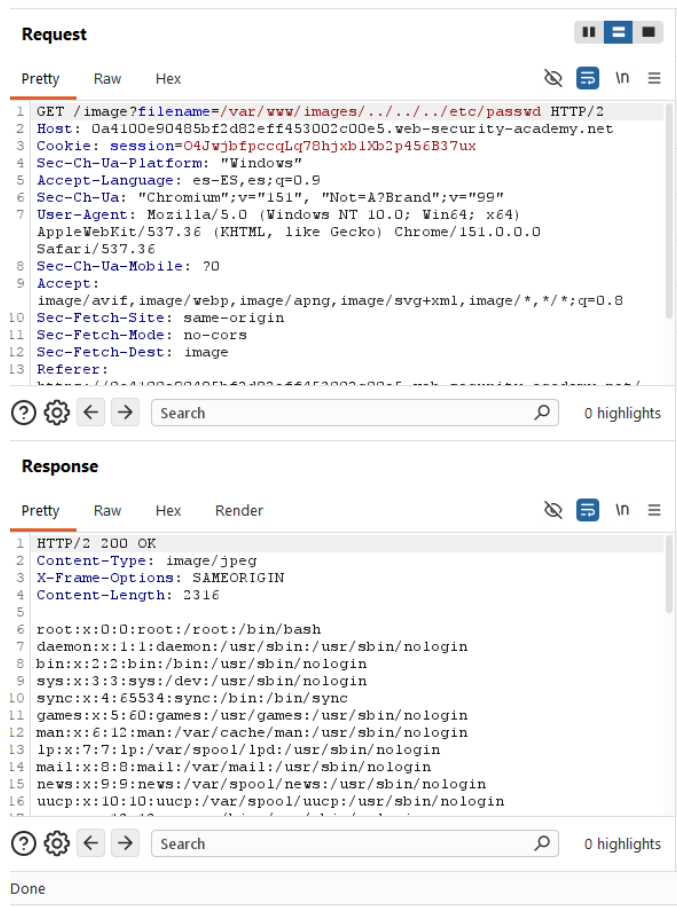


Finalmente, para evadir el control de validación de inicio de ruta, se conserva el directorio base requerido y se le concatena la secuencia de salto de directorio básica, generando el payload final:

`/var/www/images/../../../../etc/passwd` Al enviar este parámetro modificado, el ataque funciona con éxito.

El objetivo de esta inyección es aprovechar una deficiencia en la validación de las entradas del servidor. Dado que la aplicación requiere estrictamente que la ruta inicie con `/var/www/images/`, este payload pasa la primera capa de seguridad. Inmediatamente después, los saltos de directorio (`../../../../`) obligan al sistema a retroceder tres niveles (saliendo de `images`, `www` y `var`) hasta alcanzar el directorio raíz (`/`), desde donde se solicita el archivo `etc/passwd`. El archivo `/etc/passwd` es un estándar en pruebas de concepto (PoC) para vulnerabilidades de Path Traversal o Local File Inclusion (LFI), ya que es un archivo presente por defecto en sistemas basados en Unix/Linux que contiene información estructurada sobre las cuentas de usuario del sistema operativo.

Al enviar la solicitud modificada, se observa que el servidor la procesa correctamente y devuelve una respuesta con el código de estado HTTP/2 200 OK. En el cuerpo de la respuesta HTTP, el servidor expone el contenido íntegro del archivo `/etc/passwd` solicitado, mostrando claramente los registros de usuarios del sistema (tales como `root`, `daemon`, `bin`, entre otros). Esto confirma la explotación exitosa de la vulnerabilidad, demostrando que un atacante puede acceder a archivos sensibles alojados en el servidor.



Explicación del payload

El payload utilizado en este laboratorio consiste en una ruta mixta que combina la validación del prefijo requerido con secuencias relativas de salto de directorio:

`/var/www/images/../../../../etc/passwd` Esta estructura se introduce en el parámetro afectado y engaña a la lógica de la aplicación. Al evaluar la cadena, el filtro de seguridad verifica que los primeros caracteres coincidan con el directorio permitido (`/var/www/images/`), aprobando la solicitud. Sin embargo, al momento de procesar la lectura del archivo a nivel de sistema operativo, las secuencias `../` son interpretadas de manera legítima para navegar hacia atrás en el árbol de directorios, eludiendo la restricción lógica y revelando así la información confidencial solicitada.

Mitigación recomendada

Para prevenir vulnerabilidades de Path Traversal como la analizada en este laboratorio, es necesario implementar un control riguroso sobre la validación y el procesamiento de las entradas del usuario. Las principales medidas de mitigación incluyen:

- **Validación de ruta canónica:** Antes de validar si una ruta comienza con el directorio esperado, es fundamental "canonicalizar" (resolver) la ruta solicitada. Esto significa que la aplicación debe resolver todos los enlaces simbólicos y secuencias relativas (como `../`) utilizando funciones del sistema (por ejemplo, `realpath()` en lenguajes como PHP o equivalentes en Java/C#) para obtener la ruta absoluta real. La validación del prefijo autorizado (ej. `/var/www/images/`) debe realizarse *exclusivamente* sobre la ruta ya canonicalizada.
- **Uso de funciones de mapeo seguro (Basename):** Si el servidor solo necesita el nombre del archivo, se deben utilizar funciones integradas en el lenguaje de programación (como `basename()`) que extraigan únicamente el nombre del archivo solicitado, descartando cualquier ruta o directorio previo proporcionado en el parámetro.
- **Validación mediante listas blancas (Whitelisting):** Restringir los valores permitidos en los parámetros de entrada a un conjunto estricto de nombres de archivos válidos o identificadores predefinidos, rechazando cualquier cadena que contenga caracteres especiales, barras o rutas relativas/absolutas.